

Annex IV Technical Documentation

Regulation: EU 2024/1689 Annex IV (Art. 11) **Variant:** full **Generated:**

2026-04-22T12:27:53.151785+00:00 **Status:** draft

System: external/codebase-security-audit · Codebase Security Audit · v2 · risk class limited

1. General description

- **Intended purpose:** Runs automated SAST, dependency, and secret-leak scans on a codebase and summarises findings in a structured report.
- **Provider:** SecureAudit UG (haftungsbeschränkt)
- **Contact:** [PROVIDER: accountable contact, email, phone]
- **System identifier:** external/codebase-security-audit
- **Version:** v2
- **Form:** Managed runtime (API). Executed as an ephemeral server task on agents.renemurrell.de.
- **Underlying model:** anthropic/claude-sonnet-4-6
- **Required tools:** shell
- **User interface summary:** Operated via REST API (POST /v1/tasks) or CLI (agents-cli run). A browser dashboard surfaces status, results, and evidence packs.
- **IFU reference:** capability-card@v2
- **Third-country variants:** [PROVIDER: list Member-State-specific variants, if any; otherwise 'none']

2. Detailed description

- **Development methodology:** [PROVIDER: development process, design decisions, validation method]

Third-party components:

- Foundation model: anthropic/claude-sonnet-4-6
- Tool: shell
- Runtime: agents.renemurrell.de managed runtime
- **System architecture:** Each task runs on an isolated ephemeral server provisioned from a pre-baked snapshot, executed by the agent runtime, then destroyed. State is persisted to the platform event log, not to the compute node.

Data requirements:

- **input_schema:** [{'name': 'repo_url', 'type': 'string', 'required': True}]
- **output_schema:** [{'name': 'output.md', 'type': 'markdown', 'guaranteed': True}]
- **constraints:** {}

- **training_data_summary:** [PROVIDER: source, licensing, curation, bias analysis; 'not applicable' if the agent does not fine-tune]
- **Validation and testing:** [PROVIDER: test corpora, acceptance criteria, drift monitoring]
- **Pre-determined changes:** [PROVIDER: changes that do not trigger re-assessment, per Art. 43]
- **Continuous-learning behaviour:** No online learning. The agent is stateless between executions; model weights are fixed per capability-card version.

3. Monitoring information

- **Capabilities:** Runs automated SAST, dependency, and secret-leak scans on a codebase and summarises findings in a structured report.

Known limitations:

- Outputs depend on the underlying LLM; factual claims require verification.
- Performance degrades on inputs outside the documented schema or constraints.

Observed accuracy metrics:

- **total_executions:** 0
- **success_count:** 0
- **observed_success_rate:** None
- **trust_score:** None
- **avg_duration_seconds:** None

Foreseeable unintended outcomes:

- [PROVIDER: incorrect outputs due to ambiguous inputs]
- [PROVIDER: privacy leakage if sensitive data is included in the prompt]
- [PROVIDER: bias reinforcement if the underlying model is biased]

Human oversight measures:

- Approval gates for high-risk agents (Art. 14)
- Immutable event log per execution (Art. 12)
- Signed capability cards with declared capabilities (Art. 13)
- Art. 50 provenance header on every output

4. Appropriateness of performance metrics

Platform-provided metrics:

- 5-factor trust score (success rate, duration accuracy, volume, recency, ratings)
- Observed success rate and failure-class breakdown from the event log
- Execution latency (avg and p95) per agent version
- **Metric rationale:** [PROVIDER: why the chosen metrics are appropriate for the intended purpose]
- **Robustness testing:** [PROVIDER: adversarial inputs, edge cases, redundancy behaviour]

Cybersecurity testing:

- 3-path secret isolation (consumer / provider / platform)
- Ephemeral compute: no persistent tenant state
- Firewalled VPC, no SMTP egress

5. Risk management system

- **Platform risk class:** `limited`
- **RMS owner:** [PROVIDER: role accountable for the Art. 9 risk management system]

Identified risks:

- [PROVIDER: inaccurate outputs leading to harm]
- [PROVIDER: discriminatory outcomes]
- [PROVIDER: data leakage via output content]

Mitigation measures:

- [PROVIDER: mitigation measure with owner and review cadence]
- **Review cadence:** quarterly

6. Changes

- **Current version:** v2
- **Version history policy:** Each published change increments the agent capability card version. The platform stores prior versions and keeps their event logs for the Art. 19 retention window.
- **Substantial modification definition:** [PROVIDER: define what constitutes a substantial modification per Art. 43]

7. Applied standards

Harmonised standards applied:

- [PROVIDER: list applied harmonised standards once published; CEN-CENELEC JTC 21 target Q4 2026]

Common specifications applied:

- (none)

Other adopted solutions:

- ISO/IEC 42001 (AI management system) as baseline reference where applicable

8. Declaration of conformity

- **DoC reference:** [PROVIDER: attach EU Declaration of Conformity for external/codebase-security-audit v2 per Annex V]

- **CE marking affixed:** False
- **EU database registration (Art. 49):** [PROVIDER: EU database registration identifier, per Art. 49]

9. Post-market monitoring

- **Plan summary:** [PROVIDER: post-market monitoring plan per Art. 72: data collection, analysis, re-assessment triggers]
- **Incident reporting process (Art. 73):** Serious incidents reported to the MSA within Art. 73 deadlines (15 days standard, 10 days critical infrastructure, 2 days widespread).

Feedback channels:

- Consumer ratings and complaint forms on the platform
 - Trust-score drift monitoring
 - [PROVIDER: additional channels: customer support, user surveys, etc.]
-

Generated by the agents.renemurrell.de Annex IV scaffolding engine. Sections marked [PROVIDER: ...] require completion by the placing-on-market organisation. Retain this document for 10 years per Art. 18.